

CAPÍTULO 5 · RESUMO DE ESTUDO

Segurança de Redes e Desenvolvimento de Software

As camadas de proteção de uma rede corporativa (perímetro, segmentação, VPN, zero trust, DNS, IoT, monitoramento, auditoria), a segurança integrada ao ciclo de vida do software (DevSecOps, SSDF) e a segurança em nuvem/multi-cloud – condensado para revisão antes da prova.

Curso Educação a Distância · Segurança e Auditoria de Sistemas de Informação

Base Nist SP 800-41/53/61/77/125B/207/218, IEEE 802.1X, CIS Controls v8.1, Owasp Top 10, ISO/IEC 27034-3, Cyber Resilience Act (UE)

1. Segurança de redes
2. DevSecOps & nuvem
3. Cibersegurança & ciberdefesa
- Termos-chave
- Revisão rápida

01

Segurança de redes de computadores

Compreende políticas, processos e tecnologias que protegem comunicações e dados contra acessos não autorizados, ataques e perdas de informação – em camadas, do perímetro ao endpoint.

CAMADA	O QUE FAZ	PADRÃO / FERRAMENTA
Perímetro	NGFW combina inspeção profunda de pacotes, análise de aplicação e IDS/IPS – supera o firewall tradicional (só IP/porta/protocolo), que falha contra ameaças na camada de aplicação.	Nist SP 800-41r1 · Cisco Safe

CAMADA	O QUE FAZ	PADRÃO / FERRAMENTA
Acesso interno	NAC garante que só dispositivos/usuários permitidos acessem a rede, verificando conformidade (antivírus, patches) antes de liberar.	IEEE 802.1X-2020
Segmentação	Divide a rede em zonas independentes: se um invasor compromete uma área, não alcança as demais — reduz a movimentação lateral.	Nist SP 800-125B
Acesso remoto	VPNs criam túneis criptografados até a rede corporativa, com autenticação mútua entre cliente e servidor.	IPsec / SSL-TLS · SP 800-77r1
Zero trust	Nenhuma conexão (interna ou externa) é confiável sem verificação; toda solicitação é autenticada e autorizada em tempo real, conforme identidade, dispositivo, local e sensibilidade.	Nist SP 800-207 (ZTA)
DNS & navegação	DNSSEC usa assinaturas digitais para confirmar a autenticidade das respostas DNS; gateways/proxies filtram tráfego HTTP/HTTPS contra phishing e malware.	Nist SP 800-81r2 · Cisco Safe
Físico & IoT	Controle de acesso a ambientes, câmeras e vigilância unidos à proteção lógica; dispositivos IoT exigem gestão de identidade e atualização segura de firmware.	ABNT ISO/IEC 27002 · Nistir 8259 · SP 800-213
Monitoramento & endpoints	Siem, EDR e XDR correlacionam logs em tempo real; MDM protege dispositivos móveis; hardening reduz a superfície de ataque de cada equipamento.	SP 800-61r3 · SP 800-92 · Cisa · CIS Benchmarks
Auditoria	Avalia periodicamente a conformidade dos controles: varreduras de vulnerabilidade, revisão de regras de firewall, inspeção de logs e simulações de incidentes.	SP 800-53A · ABNT NBR ISO 19011

RESPOSTA A INCIDENTES — AS 5 ETAPAS

Preparação → detecção e análise → contenção, erradicação e recuperação → lições aprendidas. Um incidente é qualquer situação que possa afetar confidencialidade, integridade ou disponibilidade das informações (Nist SP 800-61r3).

DEFESA EM PROFUNDIDADE

O conceito que une todas as camadas acima: múltiplas barreiras de segurança trabalhando juntas para **prevenir, detectar e reagir** a ameaças de forma coesa — nenhuma camada isolada é suficiente.

02

Segurança no desenvolvimento de software

DevSecOps incorpora segurança em todas as fases do ciclo de vida do software — desde o planejamento, não como etapa final — reduzindo custos e melhorando a confiabilidade.

Secure Software Development Framework (SSDF) — 4 grupos de práticas

PO

Preparar a organização

Capacitar pessoas, processos e tecnologias para um desenvolvimento seguro.

PS

Proteger o software

Prevenir adulterações e acessos indesejados aos componentes.

PW

Produzir software seguro

Desenvolver com o menor número possível de vulnerabilidades.

RV

Responder a vulnerabilidades

Detectar e corrigir falhas após o lançamento, evitando recorrências.

FRAMEWORK	FOCO
CIS Controls v8.1	18 controles essenciais; o Controle 16 trata da proteção de software, com Sast e Dast automatizados em CI/CD.
Owasp Top 10	Os 10 riscos mais significativos em aplicações web: falhas de criptografia, injeções de código, configurações inseguras, componentes obsoletos etc.
ISO/IEC 27034-3:2023	Diretrizes para integrar segurança da informação ao processo de desenvolvimento de software.

SAST X DAST

Sast (static application security testing) analisa o código-fonte *antes* de executar o software.

Dast (dynamic application security testing) simula ataques *durante* a execução, em tempo real. Ambos são automatizados em pipelines de integração e entrega contínua (CI/CD).

A **auditoria em ambientes de desenvolvimento** avalia conformidade, eficácia e maturidade dos controles em todo o ciclo de vida — tanto pontos técnicos (análise de código, dependências, CI/CD) quanto processuais (segregação de funções, controle de acesso, rastreabilidade), seguindo a ABNT NBR ISO 19011.

Segurança em nuvem e multi-cloud

No **modelo de responsabilidade compartilhada** (AWS, Microsoft, Google), o provedor cuida da infraestrutura física e virtual; o cliente gerencia a proteção de **identidades, redes e dados**. Práticas essenciais: IAM com MFA e menor privilégio, CSPM (identifica desvios de configuração) e CIS Benchmarks.

Zero trust + Sase — arquitetura cross-domain

O **Sase** (secure access service edge) integra segurança e conectividade em um único modelo baseado em nuvem, colocando os princípios do zero trust em prática de forma consistente entre domínios:

SD-WAN

Gateway web seguro

CASB

FWaaS

Acesso zero trust

03

Cibersegurança e ciberdefesa

A união entre segurança de rede, desenvolvimento seguro e proteção em nuvem forma a base da resiliência organizacional — mas o cenário atual exige olhar além da empresa individual.

Controles de perímetro e segmentação limitam a movimentação lateral; o DevSecOps minimiza vulnerabilidades desde a codificação; zero trust e Sase uniformizam o acesso em ambientes distribuídos; auditorias constantes garantem conformidade e promovem melhorias contínuas.

A conexão entre cadeias de suprimento digitais, dispositivos IoT e infraestruturas essenciais — somada a regulamentações como o **Cyber Resilience Act** da União Europeia — transforma incidentes em **riscos sistêmicos**, que afetam serviços fundamentais, a economia e a própria soberania.

CIBERSEGURANÇA X CIBERDEFESA

Cibersegurança é a responsabilidade operacional de empresas (e cidadãos) na proteção de seus sistemas. **Ciberdefesa** orchestra prevenção, detecção, resposta e dissuasão em níveis setoriais e governamentais — uma missão de Estado voltada à soberania digital e às infraestruturas críticas. As duas precisam se integrar para reduzir a superfície de ataque em escala nacional.

CYBER RESILIENCE ACT (UE, 2024)

Até 2027, produtos digitais vendidos na União Europeia precisarão de certificação CE de conformidade em segurança cibernética, responsabilizando os fabricantes por vulnerabilidades.

↳

Termos-chave

Vocabulário que costuma aparecer em questões de múltipla escolha.

NGFW

Next-generation firewall — combina inspeção de pacotes, análise de aplicação e IDS/IPS.

Spoofing

Falsificação de endereço ou identidade de um dispositivo/servidor para enganar o usuário.

MDM

Mobile device management — gerencia e protege dispositivos móveis remotamente.

CSPM

Cloud security posture management — identifica desvios de configuração em nuvem.

Sase

Secure access service edge — integra segurança e conectividade num modelo em nuvem.

NAC

Network access control — controla quem pode acessar a rede internamente.

DNSSEC

Extensão do DNS que usa assinaturas digitais para autenticar respostas.

Hardening

Reforço de segurança que reduz a superfície de ataque de um dispositivo.

CASB

Cloud access security broker — visibilidade e controle sobre o uso de serviços em nuvem.

Movimentação lateral

Quando um invasor, após comprometer um ponto, se desloca para outras áreas da rede.



Revisão rápida antes da prova

Confira se você consegue responder a cada ponto sem consultar o texto.

☐ Explicar por que um firewall tradicional não é suficiente contra ameaças na camada de aplicação, e o que o NGFW acrescenta.

☐ Diferenciar NAC (controle de acesso) de segmentação (limite de movimentação) dentro da rede.

☐ Descrever o princípio central do zero trust e como ele avalia cada solicitação de acesso.

- ☐ Explicar o que é spoofing de DNS e como o DNSSEC previne esse ataque.
- ☐ Listar as 4 etapas de resposta a incidentes (preparação, detecção/análise, contenção/erradicação/recuperação, lições aprendidas).
- ☐ Diferenciar Siem, EDR e XDR quanto à função de cada um.
- ☐ Listar os 4 grupos do SSDF (PO, PS, PW, RV) e o que cada um cobre.
- ☐ Diferenciar Sast (código, antes de executar) de Dast (execução, tempo real).
- ☐ Explicar o modelo de responsabilidade compartilhada em nuvem: o que cabe ao provedor e o que cabe ao cliente.
- ☐ Diferenciar cibersegurança (responsabilidade das empresas) de ciberdefesa (missão de Estado).



Referências do capítulo

ABNT. NBR ISO 19011:2018; NBR ISO/IEC 27001:2024; NBR ISO/IEC 27002:2022.

AWS; Microsoft. Shared responsibility model / Shared responsibility in the cloud. [s.d.].

CIS. CIS Controls v8.1 (2021); CIS Benchmarks (2023).

CISCO. Cisco Safe security architecture toolkit (2018); Zero trust architecture guide (2023).

CISA. Mobile device cybersecurity checklist for organizations (2021); Zero trust maturity model v2.0 (2023).

CSA — Cloud Security Alliance. Security guidance for cloud computing v5.0 (2024).

IEEE. Std 802.1X-2020 — Port-Based Network Access Control.

ISO/IEC. 27402:2023 (IoT security); 27034-3:2023 (application security management).

Nist. SP 800-41r1 firewalls; SP 800-53/53A; SP 800-61r3 incident response; SP 800-77r1 / SP 800-113 VPNs; SP 800-81r2 DNS; SP 800-92 log management; SP 800-125B segmentação; SP 800-207/207A zero trust; SP 800-213 IoT; SP 800-218 SSDF; Nistir 8259.

Owasp Foundation. Owasp Top 10: 2021.

RODRIGUES, R. W.; FERNANDES, J. H. C. Auditoria e conformidade de segurança da informação (GSIC345), 2011.

União Europeia. Regulamento (UE) 2024/2847 — Cyber Resilience Act, 2024.

Resumo gerado a partir do capítulo "Segurança de redes e desenvolvimento de software" (SEG_AUD_SIS_05_ACE_2025)
para revisão de prova.